

Industrial Security (Bachelor)

Exercise Sheet – Section 05

Threat Landscape

Exercise 5.1 – ATT&CK Mapping

Pick one case study: Stuxnet, Ukraine 2015, Industroyer, TRITON, Colonial, or CyberAv3ngers/Unitronics.

1. Identify at least five MITRE ATT&CK for ICS techniques used.
2. For each, propose one detection that a defender could implement.
3. Present the mapping as a three-column table: *Tactic, Technique ID, Detection idea*.

Exercise 5.2 – Lab: Shodan Reconnaissance (ethical)

See `labs/lab-05-shodan`.

1. Create a free Shodan account.
2. Search for `port:502 country:DE` and report what kinds of systems appear.
3. Repeat for "Siemens" `port:102` and "Unitronics" `port:20256`.
4. In 5–10 lines: why are these systems exposed, what should asset owners do, what should ISPs/CERTs do?

Caution

Read-only. Do *not* connect to, log into, or scan any discovered system.

Exercise 5.3 – Threat Modelling

For a small chemical plant with a single DCS and SIS:

1. Identify five plausible threat actors. Rank them by likelihood for this asset.
2. For the top two, sketch an attack path from initial access to physical impact.
3. Identify the choke points where a defender could break the chain.

Exercise 5.4 – Supply Chain Reasoning

A vendor announces a critical RCE CVE in their PLC runtime, fix available next quarter.

1. What compensating controls can you deploy now?
2. Who in the organisation must be informed?
3. How would you communicate the residual risk to a non-technical executive sponsor?

Exercise 5.5 – PIPEDREAM & Volt Typhoon

Read the Dragos PIPEDREAM/INCONTROLLER write-up *and* the CISA Volt Typhoon advisory. Compare them in a 1-page brief:

- Tooling – is it custom malware or living-off-the-land?
- Targets – which sectors and which assets are in scope?
- Detection – which technique would surface each first in your environment?
- Defensive priority – which one should the OT team treat as more urgent, and why?

Exercise 5.6 – Initial Access Audit

For your own (or a fictional) plant, score each of the eight initial-access vectors from the slides (spearphish, vendor compromise, Internet-exposed PLC, USB, stolen credentials, vendor remote access, weak VPN, insider) on a 1–5 scale for *exposure* (how easy is the door for an attacker) and *detection* (how likely are we to notice). Pick the worst gap and propose one specific control.